BioFrio | Perícia de rede - Parte 2

VaxGuard Connect · Módulo B · SENAI Dev Experience 2026

Objeto: reconstrução do incidente da CAM03 a partir dos 28 pacotes do arquivo fornecido. Horários em UTC-3, em 20/10/2026. Numeração correspondente à ordem original da captura.

Conclusão: há evidência de publicação de comando por host diferente do servidor autorizado, seguida de encaminhamento pelo broker e leituras CRITICO. O aquecimento já ocorria antes do comando, portanto não é possível atribuir toda a excursão exclusivamente a ele.

Evidências: análise dos bytes da captura, acompanhada de nove capturas de tela do Wireshark fornecidas pelo participante. As figuras do apêndice documentam os pacotes 13, 4, 5, 9, 11, 12, 24, 25 e 28.

Questão 1 - Reconhecimento do dispositivo

Campo	Resposta / evidência
IP do dispositivo / versão	192.168.20.31 / IPv4 (pacotes 9, 11 e 13)
Servidor/broker / versão	192.168.20.10 / IPv4 (pacotes 10, 12 e 25)
Protocolo de aplicação	MQTT sobre TCP, sem TLS; CONNECT informa nível 4 (MQTT 3.1.1)
Porta de destino	1883/TCP
Placa no JSON	ESP32 (pacotes 13 a 20 e 26 a 28)
Tópico de telemetria	biofrio/cam03/telemetria (texto nos payloads)

Questão 2 - Credenciais em texto claro

a) Usuário do painel: **tecnico.cam03**. O pacote 4 contém POST /painel/login, de 192.168.20.31 para 192.168.20.10:80.

b) Senha: **Vac@BioFrio2026**. No formulário aparece senha=Vac%40BioFrio2026. %40 é a codificação percentual do byte hexadecimal 40, que representa @; codificação de URL não é criptografia.

c) Cookie devolvido no pacote 5: **session=c6a1f09b7d2e4418**, em Set-Cookie; resposta HTTP 302 Found para /painel/cam03.

d) CONNECT MQTT do pacote 9: usuário vaxguard, senha Fr10#Cam03; client ID: vaxguard-cam03. As credenciais aparecem em texto claro nos detalhes do Wireshark (Figura 4).

Questão 2 - Falha e correções (continuação)

e) HTTP e MQTT sem TLS expõem credenciais e sessão à leitura do tráfego por quem tenha acesso à captura. Isso permite obter segredos e pode viabilizar reutilização de credenciais ou sequestro de sessão. Corrigir com HTTPS e MQTT sobre TLS com validação de certificado, identidades individuais e rotação das credenciais expostas. Para o cookie, usar Secure, HttpOnly e SameSite e renovar a sessão após autenticação. Esses atributos não aparecem no Set-Cookie capturado.

Questão 3 - Comando suspeito no broker

a) Pacote 24, 14:14:30.000: **192.168.20.66:44120** → **192.168.20.10:1883**. Tópico textual: biofrio/cam03/cmd. Conteúdo exato: **{"cmd":"VENTILACAO_OFF","cmd_id":"x90"}**.

b) Não. A origem é 192.168.20.66, diferente de 192.168.20.10. As respostas do painel e do broker vêm de .10 nos pacotes 5, 10 e 12. O repasse do pacote 25 também vem de .10, mas isso identifica o broker que encaminhou a mensagem, não o autor original.

c) Sim. O pacote 11 contém SUBSCRIBE ao tópico textual biofrio/cam03/cmd, com identificador 1 e QoS solicitado 1; o pacote 12 contém SUBACK com retorno 1. O broker encaminha a publicação ao cliente inscrito no pacote 25, às 14:14:30.040, 40 ms depois. A publicação capturada tem QoS 0; a assinatura em QoS 1 não eleva o QoS original.

d) Antes do comando: 4,8 °C/NORMAL às 14:10:05; 7,8 °C/NORMAL às 14:12:35; 8,6 °C/ATENCAO às 14:13:05; 9,2 °C/ATENCAO às 14:13:35. Depois: 10,4 °C/CRITICO às 14:15:05; 11,9 °C/CRITICO às 14:15:35; 13,5 °C/CRITICO às 14:16:05. A porta permanece FECHADA em todas essas leituras. Desligar a ventilação é compatível com agravar o aquecimento ou impedir uma resposta de mitigação. A captura não contém confirmação do atuador nem prova física da execução, e a subida já existia antes das 14:14:30.

e) Dois mecanismos centrais: (1) autenticação individual de clientes, preferencialmente certificados mTLS; (2) ACL por identidade e tópico, autorizando apenas o serviço de comandos a publicar em biofrio/cam03/cmd e o dispositivo a assinar esse tópico. Adicionalmente, verificar assinatura/HMAC do comando no firmware, com contador/nonce e validade temporal para impedir adulteração e replay. TLS sozinho não substitui autorização por tópico.

Questão 4 - Linha do tempo

a) A tabela seguinte vai do login à última leitura crítica. A conexão TCP HTTP começa às 14:10:00.000 (pacote 1).

Linha do tempo | 20/10/2026 · UTC-3

Horário	Pacote	Evento observado
14:10:00.120	4	Login HTTP: usuario=tecnico.cam03; senha em claro.
14:10:00.180	5	HTTP 302; criação do cookie de sessão.
14:10:01.020	9	CONNECT MQTT com usuário/senha visíveis.
14:10:01.040	10	CONNACK: retorno 0 (conexão aceita).
14:10:01.060	11	SUBSCRIBE ao tópico de comandos.
14:10:01.080	12	SUBACK: assinatura aceita, retorno QoS 1.
14:10:05.000	13	seq 100: 4.8 °C; NORMAL; porta FECHADA.
14:10:35.000	14	seq 101: 5.0 °C; NORMAL; porta FECHADA.
14:11:05.000	15	seq 102: 5.3 °C; NORMAL; porta FECHADA.
14:11:35.000	16	seq 103: 6.1 °C; NORMAL; porta FECHADA.
14:12:05.000	17	seq 104: 6.9 °C; NORMAL; porta FECHADA.
14:12:35.000	18	seq 105: 7.8 °C; NORMAL; porta FECHADA.
14:13:05.000	19	seq 106: 8.6 °C; ATENCAO; porta FECHADA.
14:13:35.000	20	seq 107: 9.2 °C; ATENCAO; porta FECHADA.
14:14:29.000	21	Host .66 inicia conexão TCP com o broker.
14:14:30.000	24	Host .66 publica VENTILACAO_OFF / x90.
14:14:30.040	25	Broker .10 repassa o comando ao dispositivo .31.
14:15:05.000	26	seq 108: 10.4 °C; CRITICO; porta FECHADA.
14:15:35.000	27	seq 109: 11.9 °C; CRITICO; porta FECHADA.
14:16:05.000	28	seq 110: 13.5 °C; CRITICO; porta FECHADA.

Classificação e medidas técnicas

b) A hipótese mais sustentada é uma **ação maliciosa ou comando não autorizado**: .66 publica um comando operacional sensível (24), o broker o repassa (25), e seguem leituras críticas (26-28). Considerando o servidor autorizado definido pelo enunciado, isso indica falha de controle de acesso. Não há evidência suficiente para identificar a pessoa, provar sua intenção, demonstrar como obteve acesso ou excluir falha de equipamento anterior. Não há CONNECT do host .66 na captura; não se pode afirmar que entrou anonimamente ou que usou as credenciais do pacote 9.

c) Três medidas:
1. **Criptografia de transporte:** HTTPS para o painel e MQTT/TLS (usualmente 8883), desativando acessos sem TLS e validando certificados. Protege credenciais, cookie e conteúdo em trânsito.
2. **Autenticação de mensagens:** comandos assinados ou autenticados por HMAC, verificados no dispositivo com identidade do emissor, cmd_id/nonce, contador e expiração. Rejeitar mensagens inválidas e repetidas.
3. **Controle de acesso ao broker:** credenciais/certificados individuais, proibição de acesso anônimo e ACL de menor privilégio por tópico. O dispositivo publica telemetria e recebe comandos; somente o serviço autorizado publica comandos. Registrar rejeições e revogar identidades comprometidas.

Figura 1 - Reconhecimento do dispositivo | pacote 13

Q1 e Q3(d): IPv4 .31 para .10, destino TCP 1883, tópico biofrio/cam03/telemetria; ESP32, 4,8 °C e NORMAL no conteúdo.

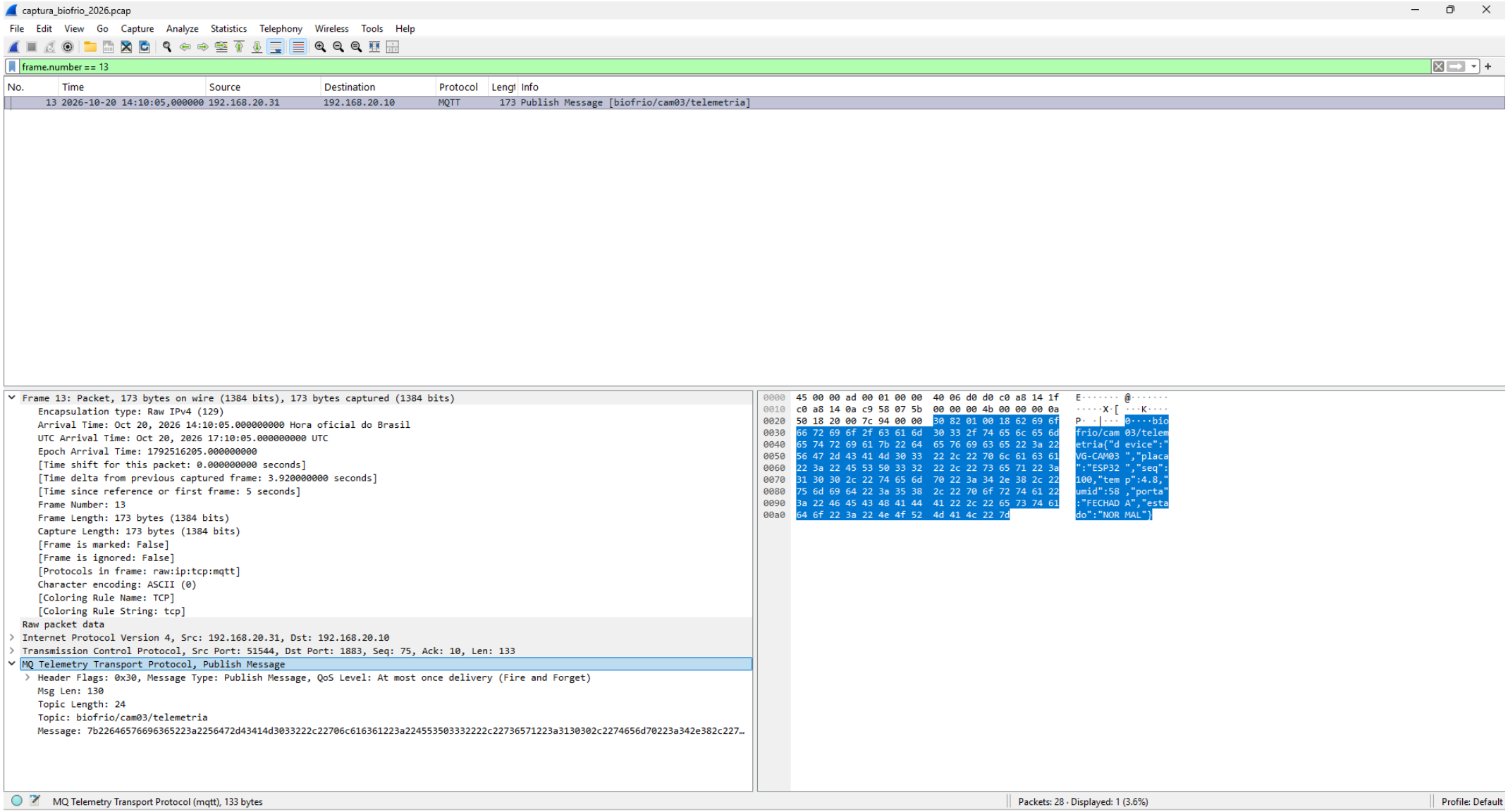


Figura 2 - Login HTTP em texto claro | pacote 4

Q2(a/b): formulário com tecnico.cam03 e Vac@BioFrio2026; os bytes mostram a codificação %40 para @.

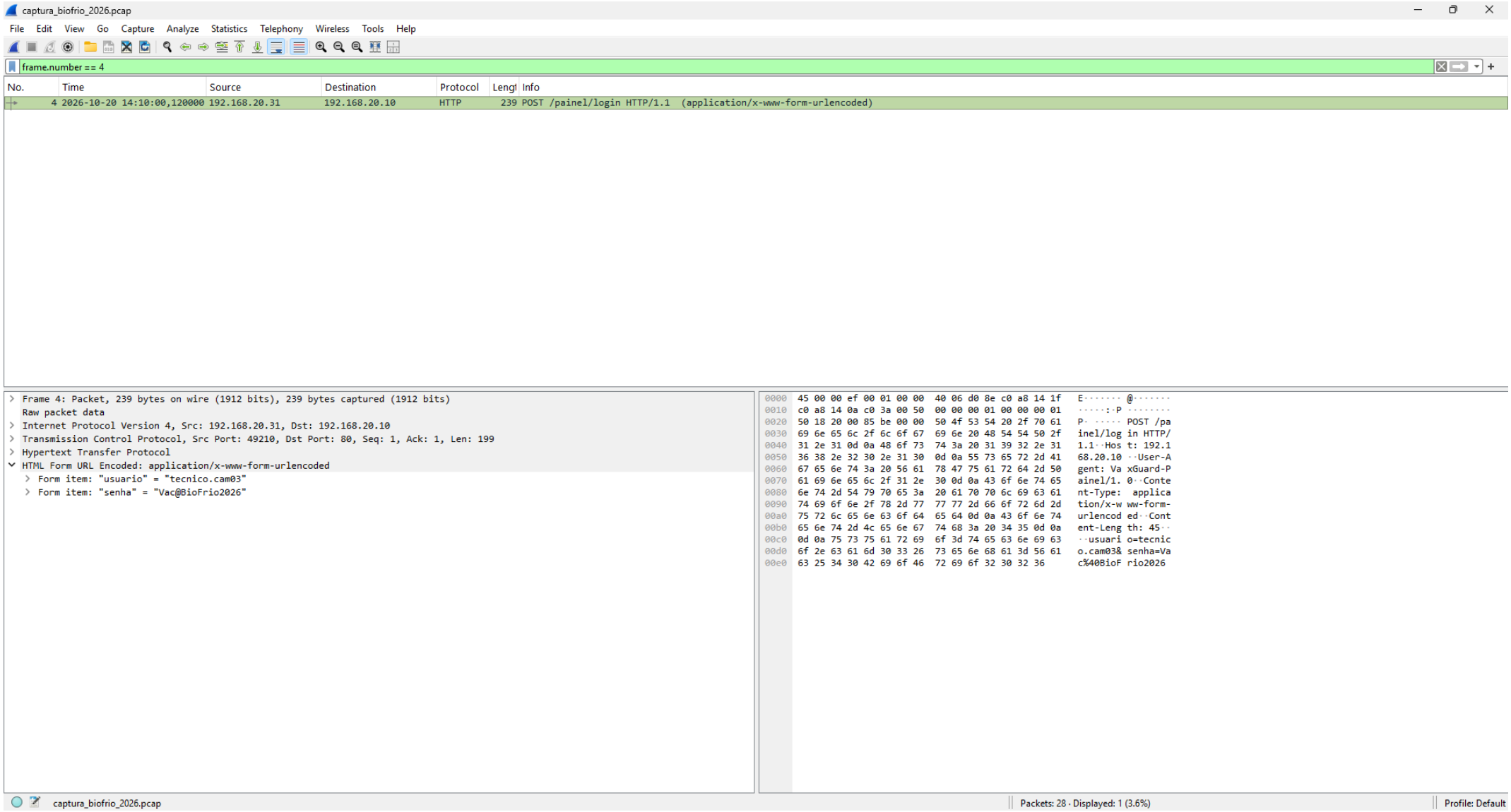


Figura 3 - Identificador de sessão exposto | pacote 5

Q2(c): HTTP 302 e Set-Cookie: session=c6a1f09b7d2e4418; Path=/.

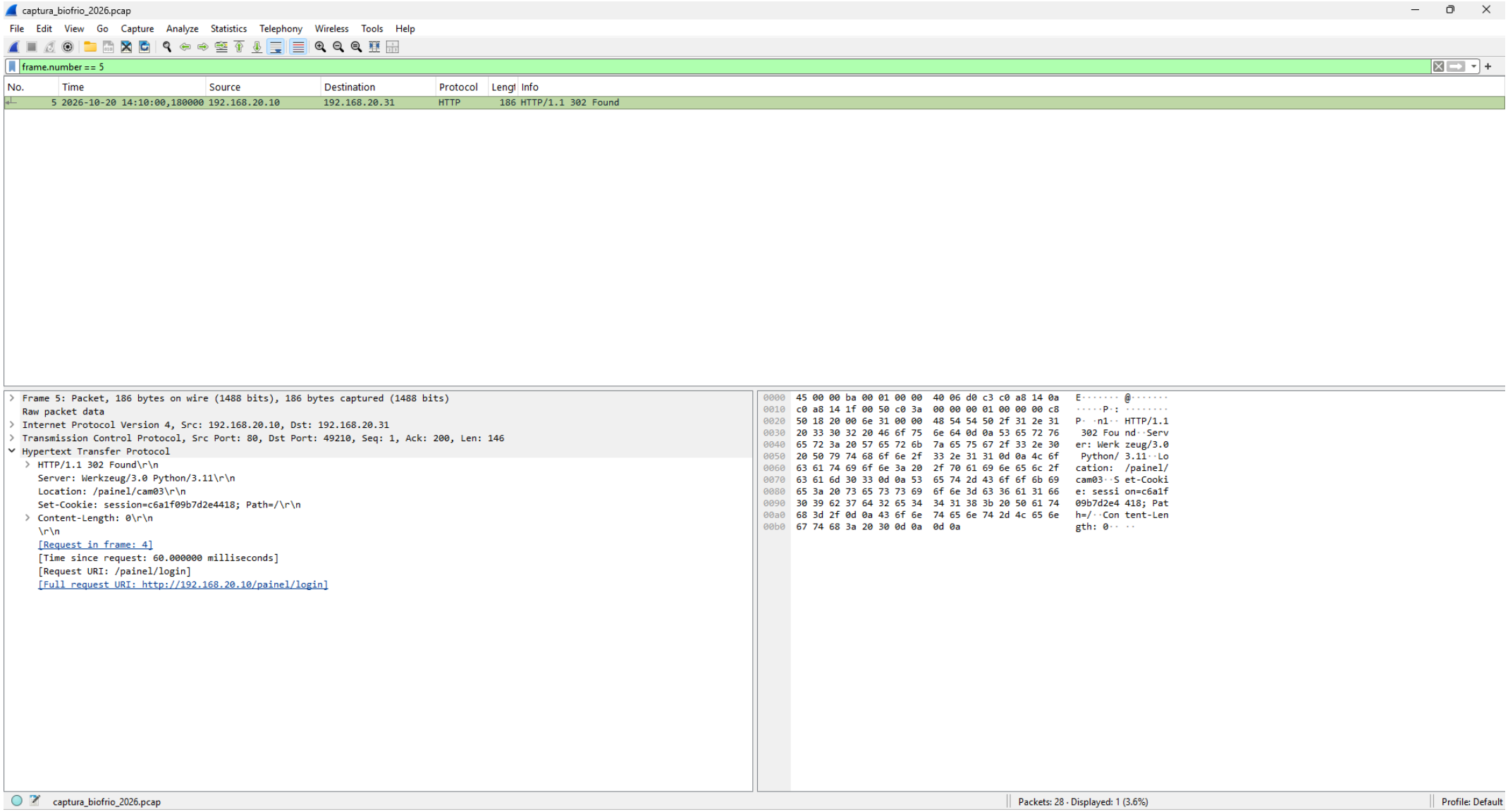


Figura 4 - Credenciais MQTT em texto claro | pacote 9

Q2(d/e): CONNECT MQTT v3.1.1, usuário vaxguard e senha Fr10#Cam03, sem proteção TLS.

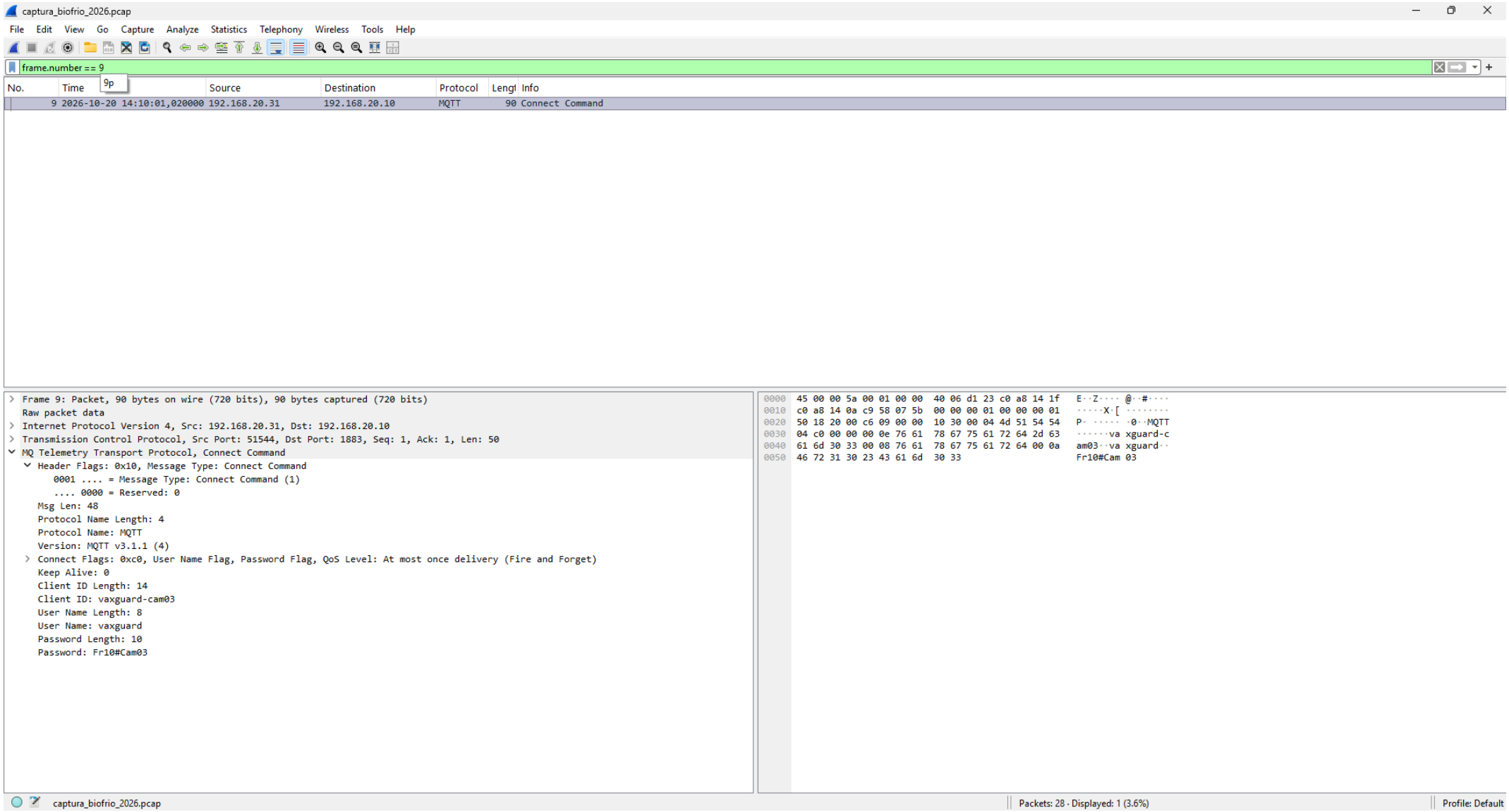


Figura 5 - Inscrição no tópico de comandos | pacote 11

Q3(c): SUBSCRIBE a biofrio/cam03/cmd; identificador 1 e QoS solicitado 1.

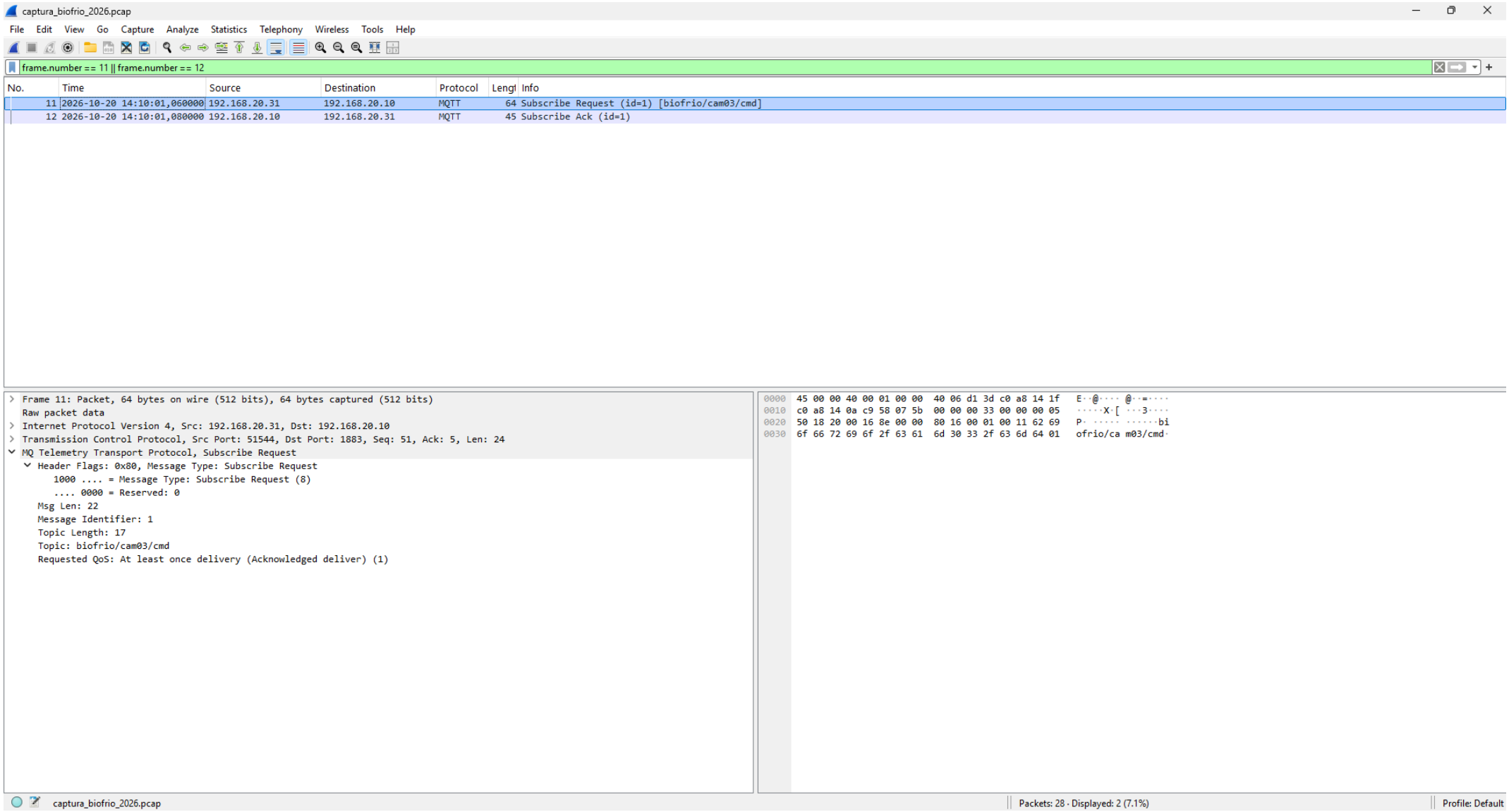


Figura 6 - Confirmação da inscrição | pacote 12

Q3(c): SUBACK do broker 192.168.20.10; identificador 1 e QoS concedido 1.

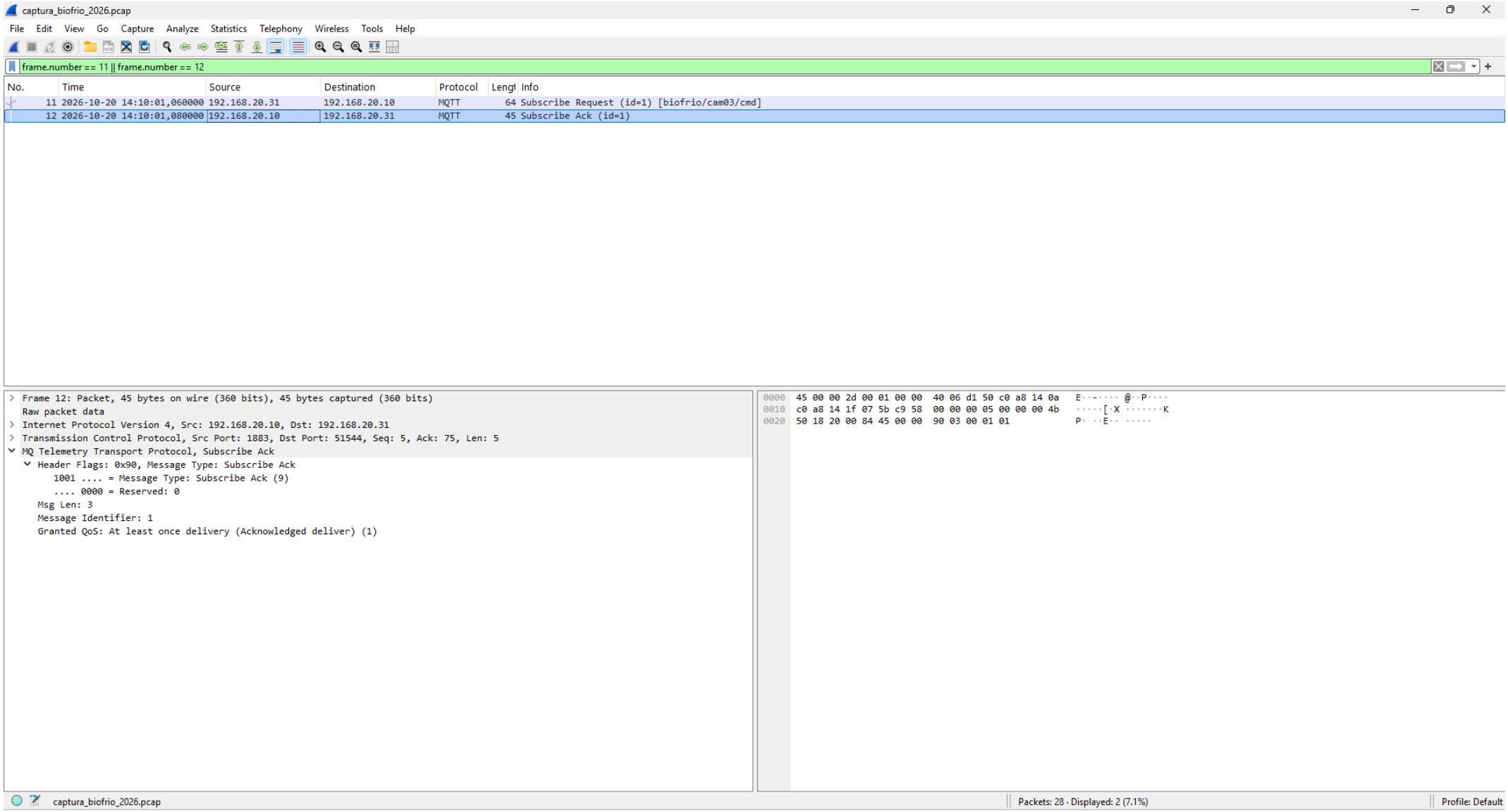


Figura 7 - Publicação do host suspeito | pacote 24

Q3(a/b): 192.168.20.66 publica VENTILACAO_OFF, cmd_id x90, às 14:14:30.000. O aviso registra ausência do CONNECT na captura.

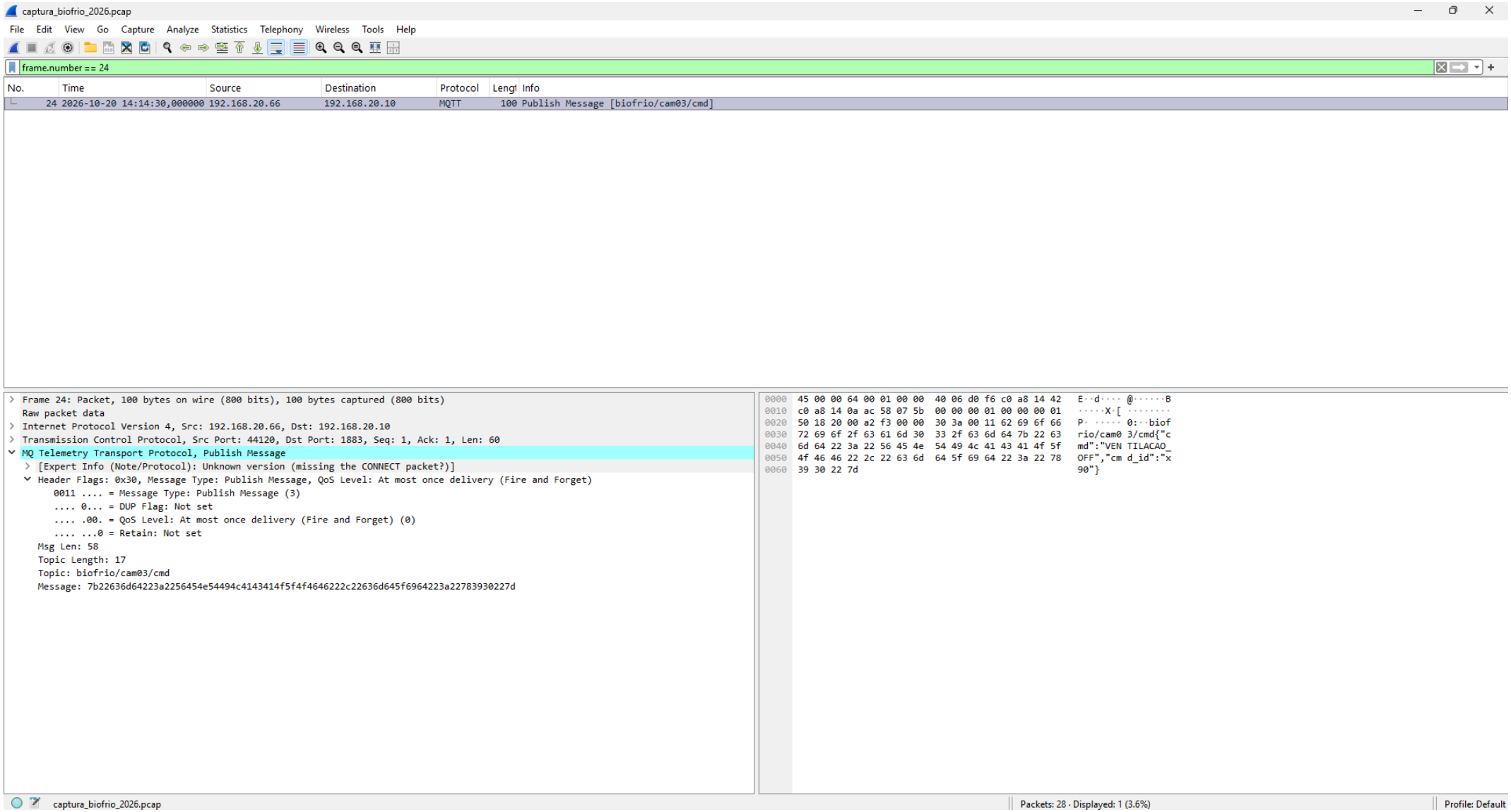


Figura 8 - Repasse do comando pelo broker | pacote 25

Q3(c): 192.168.20.10 encaminha o mesmo comando para 192.168.20.31 às 14:14:30.040; diferença de 40 ms.

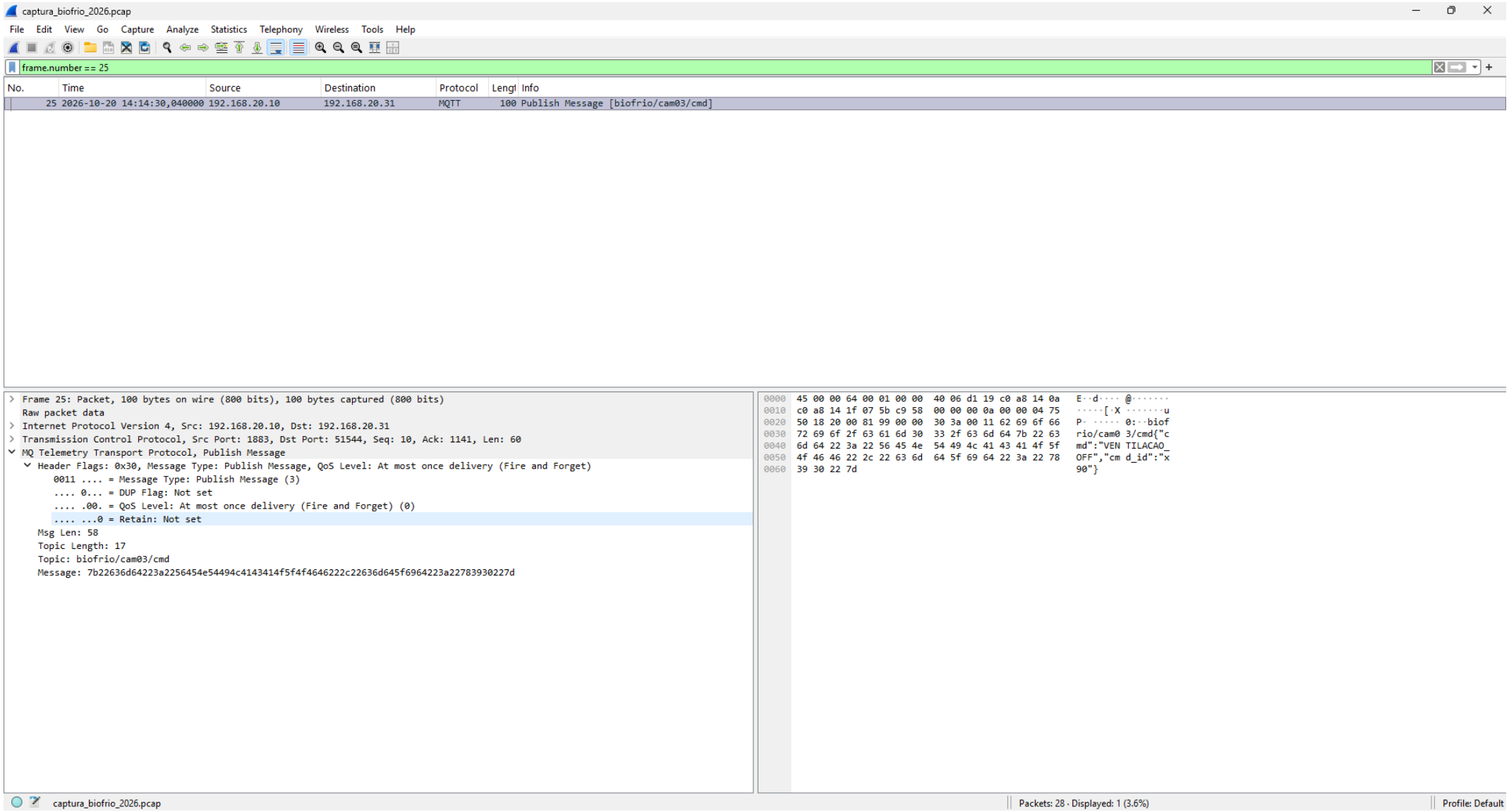


Figura 9 - Última leitura crítica | pacote 28

Q3(d) e Q4: às 14:16:05, a CAM03 publica temp 13.5, estado CRITICO e porta FECHADA. Comparar à Figura 1 e à linha do tempo.

